

Gruppenaufgabe 2

Incident Response und Wiederherstellung nach Ransomware

Szenario

Die «LogiTrans AG», ein Logistikunternehmen mit 120 Mitarbeitenden und Sitz in Basel, wurde am Sonntagabend Opfer eines Ransomware-Angriffs. Das ERP-System, die Lagerverwaltung und sämtliche Kundendatenbanken sind verschlüsselt. Die Angreifer fordern 30 Bitcoins innerhalb von 48 Stunden. Die LogiTrans AG hat keinen dokumentierten Notfallplan. Als externer IT-Krisenberater sollen Sie die Sofortmassnahmen koordinieren, die Kommunikation strukturieren und einen Wiederherstellungsplan erstellen.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Sofortmassnahmen bei einem Ransomware-Angriff priorisieren und in einer zeitkritischen Situation strukturiert umsetzen.
- Einen Krisenkommunikationsplan für interne und externe Zielgruppen entwickeln und begründen.
- Einen phasenweisen Wiederherstellungsplan mit klaren Prioritäten, Verantwortlichkeiten und Zeitvorgaben erstellen.

Arbeitsauftrag

Erarbeiten Sie in Ihrer Kleingruppe einen vollständigen Krisenreaktionsplan für die «LogiTrans AG». Definieren Sie die Sofortmassnahmen für die ersten 60 Minuten, erstellen Sie einen Kommunikationsplan für Mitarbeitende, Kunden, Behörden und Medien, und entwickeln Sie einen phasenweisen Wiederherstellungsplan für die kritischsten Systeme.

Ergebnis

Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie die drei wichtigsten Sofortmassnahmen, Ihren Kommunikationsplan und die Reihenfolge der Systemwiederherstellung mit Begründung vorstellen.

Musterlösung A | Gruppenaufgabe 2 | Incident Response und Wiederherstellung nach Ransomware

Ansatz: Strukturiert-analytisch

1. Situationsbeurteilung

Die LogiTrans AG befindet sich in einer kritischen Lage: Drei Kerngeschäftssysteme (ERP, Lagerverwaltung, Kundendatenbank) sind verschlüsselt. Als Logistikunternehmen bedeutet dies: Keine Auftragsbearbeitung, keine Lagerbewegungen, keine Kundenkommunikation. Jede Stunde Ausfall kostet geschätzt CHF 15 000 in verlorener Produktivität. Es gibt keinen Notfallplan. Die Situation erfordert sofortiges, strukturiertes Handeln.

2. Sofortmassnahmen (erste 60 Minuten)

Min.	Massnahme	Verantwortlich	Ziel
0–5	Alle Netzwerkverbindungen trennen: Server herunterfahren, Switches abschalten, VPN-Zugänge sperren	IT-Leiter	Ausbreitung der Ransomware stoppen
5–10	Krisenteam bilden: IT-Leiter, Geschäftsführer, Logistikleiter, Kommunikationsverantwortlicher	Geschäftsführer	Entscheidungsfähigkeit herstellen
10–20	Schadensinventar erstellen: Welche Systeme sind betroffen? Welche sind intakt? Gibt es funktionsfähige Backups?	IT-Team	Lagebild gewinnen
20–30	Externen IT-Forensik-Dienstleister kontaktieren und beauftragen	Geschäftsführer	Professionelle Unterstützung sichern
30–45	Polizei (Kantonspolizei Basel-Stadt) und NCSC informieren	Geschäftsführer	Rechtliche Pflichten erfüllen, Ermittlungen ermöglichen
45–60	Entscheid über Lösegeldforderung: Empfehlung NICHT zu zahlen, sofern Backup-Optionen bestehen	Krisenteam	Strategische Entscheidung treffen

3. Kommunikationsplan

3.1 Interne Kommunikation (Mitarbeitende)

Zeitpunkt	Kanal	Inhalt
Sofort (Stunde 1)	SMS/Telefon an Abteilungsleiter	«IT-Sicherheitsvorfall. Alle Systeme gesperrt. Weitere Infos folgen.»
Stunde 2	E-Mail via private Adressen oder Messenger	Detaillierte Information: Was ist passiert, was wird getan, was dürfen Mitarbeitende tun und nicht tun
Täglich	Kurz-Briefing per Video/Telefon	Statusupdate: Fortschritt der Wiederherstellung, voraussichtliche Dauer

Kernbotschaft intern: «Wir haben die Situation unter Kontrolle. Bitte nutzen Sie keine Firmensysteme, bis wir Entwarnung geben. Ihre Arbeitsplätze sind nicht gefährdet.»

3.2 Externe Kommunikation (Kunden)

Zeitpunkt	Kanal	Inhalt
Stunde 3–4	Telefon an Top-20- Kunden	Persönliche Information über mögliche Lieferverzögerungen
Stunde 4–6	E-Mail an alle Kunden	Offizielle Mitteilung: IT-Vorfall, temporäre Einschränkungen, Ansprechperson
Täglich	E-Mail/Website	Statusupdates bis zur vollständigen Wiederherstellung

Kernbotschaft extern: «Wir sind von einem IT-Sicherheitsvorfall betroffen und arbeiten mit Hochdruck an der Lösung. Ihre Aufträge sind erfasst und werden schnellstmöglich bearbeitet.»

3.3 Behörden und Medien

- **Polizei/NCSC:** Formelle Anzeige innerhalb der ersten Stunde. Kooperation bei Ermittlungen.
- **Medien:** Nur auf Anfrage reagieren. Vorbereitetes Statement: «Die LogiTrans AG ist Opfer eines Cyberangriffs geworden. Wir arbeiten mit den Behörden zusammen und informieren, sobald weitere Details vorliegen.»

4. Phasenweiser Wiederherstellungsplan

Phase 1: Forensik und Schadensbewertung (Tag 1–2)

- Forensische Sicherung aller betroffenen Systeme
- Identifikation des Angriffsvektors (Phishing? RDP? Supply Chain?)
- Bewertung der Backup-Situation: Sind Offline-Backups vorhanden und intakt?
- Schliessung der Sicherheitslücke, die den Angriff ermöglicht hat

Phase 2: Wiederherstellung kritischer Systeme (Tag 2–5)

Priorität	System	Begründung	Ziel-RTO
1	ERP-System	Auftragsabwicklung, Rechnungsstellung, Kernprozess	48 Stunden
2	Lagerverwaltung	Ohne Lagerverwaltung keine Kommissionierung und kein Versand	72 Stunden
3	Kundendatenbank	Kundenkommunikation und CRM-Funktionalität wiederherstellen	96 Stunden
4	E-Mail-System	Kommunikationsfähigkeit intern und extern vollständig wiederherstellen	96 Stunden
5	Arbeitsplätze	Neuinstallation aller Endgeräte mit sauberem Image	5–7 Tage

Phase 3: Stabilisierung und Monitoring (Tag 5–35)

- Verstärkte Überwachung aller wiederhergestellten Systeme (30 Tage)
- Tägliche Log-Analyse auf verdächtige Aktivitäten
- Schrittweise Wiederherstellung nicht-kritischer Systeme

Phase 4: Nachbereitung (ab Tag 14)

- Detaillierter Incident-Report für Geschäftsleitung und Verwaltungsrat
- Lessons-Learned-Workshop mit dem gesamten IT-Team
- Erstellung eines formalen Incident-Response-Plans für zukünftige Vorfälle

5. Empfehlung zur Lösegeldforderung

Die klare Empfehlung an das Krisenteam: Nicht zahlen. Begründung:

1. Es gibt keine Garantie für die Entschlüsselung.
2. Die Zahlung finanziert kriminelle Organisationen und macht die LogiTrans AG zu einem attraktiven Wiederholungsziel.
3. Sofern funktionsfähige Backups existieren, ist die eigenständige Wiederherstellung der sichere Weg.

4. Das NCSC und die Strafverfolgungsbehörden raten einhellig von Zahlungen ab.

6. Fazit

Die Krise bei der LogiTrans AG zeigt die Konsequenzen eines fehlenden Notfallplans. Die hier vorgeschlagene Struktur – Sofortmassnahmen, Kommunikationsplan, phasenweise Wiederherstellung – bildet das Grundgerüst, das die LogiTrans AG nach der Krise als formalen Incident-Response-Plan institutionalisieren sollte. Die wichtigste Erkenntnis: Ein Notfallplan muss vor der Krise existieren, nicht erst während der Krise erstellt werden.

Musterlösung B | Gruppenaufgabe 2 | Incident Response und Wiederherstellung nach Ransomware

Ansatz: Praxisnah-narrativ

1. Sonntagabend, 22:30 Uhr: Der Anruf

Der IT-Leiter der LogiTrans AG erhält um 22:30 Uhr einen Anruf vom Nacht-Disponenten: «Die Bildschirme im Lager zeigen alle dieselbe rote Nachricht. Nichts funktioniert mehr.» Der IT-Leiter fährt sofort ins Büro. Was er vorfindet, bestätigt seinen schlimmsten Verdacht: Ransomware. Auf jedem Bildschirm prangt die Forderung: 30 Bitcoins in 48 Stunden.

Er ruft den Geschäftsführer an. Dieser ist geschockt: «Wir haben doch Antivirus! Was machen wir jetzt?» Die ehrliche Antwort: Es gibt keinen Plan. Also müssen wir jetzt einen machen – in Echtzeit.

2. Die ersten 60 Minuten: Ruhe bewahren, richtig handeln

Minute 0–10: Stecker ziehen – buchstäblich.

Das Allerwichtigste in den ersten Minuten: Die Ausbreitung stoppen. Der IT-Leiter schaltet den zentralen Netzwerk-Switch ab. Damit ist das gesamte Firmennetz offline. Brutal, aber notwendig. Jede Minute, die die Ransomware weiter läuft, sind mehr Daten verloren. Gleichzeitig werden alle VPN-Zugänge gesperrt – wir wissen nicht, ob die Angreifer noch im Netzwerk sind.

Minute 10–20: Das Krisenteam zusammenrufen.

Der Geschäftsführer ruft die wichtigsten Personen an: IT-Leiter, Logistikleiter, Leiterin HR (für Mitarbeiterkommunikation), Finanzchef. Alle kommen ins Büro oder schalten sich per Telefon dazu. Die erste Frage: «Haben wir Backups?» Der IT-Leiter prüft: Es gibt ein Cloud-Backup, das täglich läuft. Aber ist es intakt? Ist es auch verschlüsselt? Das muss sofort geklärt werden.

Minute 20–40: Hilfe holen.

Der Geschäftsführer kontaktiert den IT-Dienstleister, der die Firewall betreut. Dieser empfiehlt einen spezialisierten Forensik-Dienstleister in Zürich. Gleichzeitig ruft der

Geschäftsführer bei der Kantonspolizei an und erstattet Anzeige. Und er informiert das NCSC über das Online-Meldeformular.

Minute 40–60: Erste Lagebeurteilung.

Das Cloud-Backup scheint intakt – die Angreifer hatten offenbar keinen Zugriff auf die Cloud-Zugangsdaten, weil diese separat verwaltet werden. Ein Glück. Aber das Backup ist vom Freitagabend – zwei Tage Daten fehlen. Besser als nichts, aber es bedeutet: Die Aufträge von Samstag und Sonntag müssen manuell nacherfasst werden.

3. Montag Morgen: 120 Mitarbeitende wollen wissen, was los ist

Um 6:00 Uhr morgens stehen die ersten Lagermitarbeitenden vor verschlossenen Systemen. Die Leiterin HR hat in der Nacht eine SMS-Kette vorbereitet: «Liebe Kolleginnen und Kollegen, wir sind von einem IT-Sicherheitsvorfall betroffen. Bitte schalten Sie keine Computer ein. Kommen Sie normal zur Arbeit – wir informieren Sie um 8:00 Uhr im Aufenthaltsraum.»

Um 8:00 Uhr hält der Geschäftsführer eine kurze Ansprache. Er erklärt sachlich, was passiert ist, was getan wird, und dass niemand seinen Arbeitsplatz verliert. Die Lagermitarbeitenden werden gebeten, auf Papier zu arbeiten – manuelle Kommissionierscheine, handschriftliche Lieferscheine. Es ist mühsam, aber es funktioniert. Die Büromitarbeitenden, deren Arbeit vollständig von IT abhängt, werden zunächst nach Hause geschickt.

4. Die Kundenkommunikation: Proaktiv statt defensiv

Der Logistikleiter übernimmt die Kundenkommunikation. Er ruft die zehn grössten Kunden persönlich an, noch bevor diese von selbst anrufen. Die Botschaft: «Wir haben ein technisches Problem. Ihre Ware im Lager ist sicher. Es kann zu Verzögerungen von ein bis zwei Tagen kommen. Wir halten Sie auf dem Laufenden.» Die Reaktionen sind überraschend verständnisvoll – Transparenz schafft Vertrauen.

An alle weiteren Kunden geht eine E-Mail vom privaten Konto des Geschäftsführers (da der Mailserver verschlüsselt ist): sachlich, knapp, mit einer Mobilnummer als Ansprechstelle.

5. Die Wiederherstellung: Was zuerst?

Am Dienstag kommt der Forensik-Dienstleister vor Ort. Seine erste Frage: «Wie ist die Ransomware reingekommen?» Die Analyse zeigt: Ein Mitarbeitender hat am Freitagabend eine Phishing-E-Mail mit einer gefälschten Sendungsbestätigung geöffnet – perfide, denn als Logistikunternehmen erhält die LogiTrans AG täglich hunderte Sendungsbenachrichtigungen.

Der Forensiker empfiehlt folgendes Vorgehen für die Wiederherstellung:

Zuerst: Das ERP-System. Ohne ERP stehen alle Geschäftsprozesse still. Die Wiederherstellung aus dem Cloud-Backup dauert zwölf Stunden. Bis Mittwochabend ist das

ERP-System wieder online – mit dem Datenstand von Freitagabend. Die Samstags-Aufträge werden aus den handschriftlichen Notizen der Disponenten nacherfasst.

Dann: Die Lagerverwaltung. Die Lagerverwaltung wird am Donnerstag aus dem Backup wiederhergestellt. Ein manueller Lagerabgleich stellt sicher, dass die Bestandsdaten korrekt sind. Das dauert einen vollen Tag, aber ist notwendig.

Danach: E-Mail und Kundendatenbank. Am Freitag gehen E-Mail-System und CRM wieder online. Die Mitarbeitenden können wieder normal kommunizieren.

Zuletzt: Die Arbeitsplätze. Über das Wochenende werden alle 80 Arbeitsplatzrechner komplett neu installiert – mit einem frischen, sauberen Image. Kein System, das potenziell kompromittiert war, wird wiederverwendet.

6. Die Lösegeldfrage: 48 Stunden laufen ab

Am Dienstag um 22:30 Uhr läuft die 48-Stunden-Frist der Erpresser ab. Das Krisenteam hatte die Entscheidung bereits am Montagmorgen getroffen: Nicht zahlen. Der Forensiker hatte bestätigt, dass das Cloud-Backup intakt ist. Damit gibt es eine Alternative zur Zahlung. Die Erpresser erhöhen den Druck mit einer zweiten Nachricht: «Wir veröffentlichen Ihre Kundendaten.» Der Geschäftsführer informiert vorsorglich den Datenschutzbeauftragten des Kantons.

Die Entscheidung, nicht zu zahlen, erweist sich als richtig. Bis Freitagabend sind alle kritischen Systeme wiederhergestellt. Der Gesamtschaden wird auf CHF 180 000 geschätzt (Forensik, Produktivitätsverlust, Neuinstallation), ist aber beherrschbar.

7. Die Lehre: Was die LogiTrans AG jetzt tun muss

Erstens: Einen Incident-Response-Plan schreiben – jetzt, wo die Erinnerung frisch ist. Der Plan wird ausgedruckt und im Tresor aufbewahrt, denn im Ernstfall funktioniert kein digitales System.

Zweitens: Offline-Backups einführen. Das Cloud-Backup hat diesmal gerettet, aber es hätte genauso gut kompromittiert sein können. Eine zusätzliche Offline-Kopie auf einem Wechselmedium im Tresor ist Pflicht.

Drittens: Mitarbeitende schulen. Der Angriff begann mit einer Phishing-Mail. Eine vierteljährliche Awareness-Schulung mit simulierten Phishing-Tests hätte das Risiko drastisch reduziert.

Viertens: Netzwerk segmentieren. Der Fileserver, das ERP und die Lagerverwaltung liefen alle im selben Netzwerk. Eine Segmentierung hätte die Ausbreitung der Ransomware begrenzt.

Die LogiTrans AG hat Glück gehabt – sie hatte ein funktionierendes Backup. Viele Unternehmen haben dieses Glück nicht. Die kommenden Wochen müssen genutzt werden, um aus dieser Krise die richtigen Lehren zu ziehen und sie umzusetzen.

